Grundlagen der IT-Sicherheit Praktikum

WS 23/24

Prof. R. Zahoransky

Hochschule Furtwangen (University of Applied Science)

Aufgabenblatt 6

Lernziele: Hashketten, Authentifizierung mit Vermittler, Log4j Schwachstelle (Ausführung von Benutzereingaben).

Abgabetermin wird in FELIX bekannt gegeben.

Von den vier Aufgaben müssen <u>drei</u> bearbeitet werden.

Aufgabe 1

Folgen Sie dem Verfahren zum Erstellen von Hash-Ketten.

a) Erstellen Sie eine Hashkette der Länge 4. Das bedeutet, dass Sie aus Ihrer Passphrase k vier Einmalpasswörter generieren. Nutzen Sie einen beliebigen Hash-Algorithmus. Sie können z.B. auf der Seite https://passwordsgenerator.net/sha1-hash-generator/ SHA1 Hashes erzeugen. Geben Sie k und alle Hashwerte an, sowie welches Hashverfahren Sie nutzen.
b) Nutzen Sie Ihre erzeugten Hash-Werte, um eine Initiale Registrierung bei einem Server durchzuführen und sich danach einmal anzumelden. Folgen Sie dem Beispiel auf Folie 15 der Vorlesung 04.
c) Angenommen Alice und Bob nutzen Hashketten, um sich zu authentifizieren. Eve hat Kontrolle über die Verbindung von Alice zu Bob. Angenommen Bob verlangt von Alice den Hashwert zu Index i. Die Antwort (P_{i+1}) wird aber von Eve abgefangen. Eve kennt nun (P_{i+1}) und hat die Übertragung an Bob verhindert. Was könnte Eve mit diesem Einmalpasswort bewirken? Wie lange wäre das Passwort gültig?
d) Angenommen Eve hat das abgefangene Einmalpasswort benutzt. Wann würde der Verlust von P_{i+1} auffallen?

Aufgabe 2

In dieser Aufgabe arbeiten wir mit dem Rechtemanagement von Linux. Nutzen Sie eine virtuelle Maschine, wenn Sie kein Linux oder MacOS benutzen. Eine schlanke Linux-Distribution finden Sie zum Beispiel unter https://xubuntu.org/download. Es reicht aus, wenn Sie dieser VM 1GB Arbeitsspeicher bereitstellen. Eine virtuelle Festplatte ist nicht nötig. Sie können direkt das ISO-Image starten und „Xubuntu ausprobieren“ wählen.

Vorbereitung:

- Öffnen Sie eine Konsole, erstellen Sie unter /tmp ein neues Verzeichnis, in welchem Sie Dateien erstellen können: `cd /tmp  mkdir test  cd test`
- Legen Sie die Benutzer alice, bob und eve mit dem Befehl `useradd <Benutzername>` an. Sie benötigen hierfür root-Rechte. Stellen Sie hierfür den Befehl `sudo` voran. `Useradd` erstellt sowohl einen neuen Benutzeraccount, als auch eine neue Gruppe mit dem gleichen Namen. Sie können die Benutzerdatenbank mit dem Befehl `cat /etc/passwd` ansehen.
- Erstellen Sie Dateien mit den Namen alice.txt, bob.txt, alicebob.txt und world.txt. Diesen Dateien werden wir nacheinander Zugriffsrechte geben, sodass nur Alice, Bob, sowohl Alice,

als auch Bob oder alle zugreifen dürfen. Schreiben Sie etwas in die Dateien hinein. Sie können hierfür z.B. den Texteditor `nano` benutzen (`nano <Dateiname>`).

a) Betrachten Sie die Ausgabe von `ls -l`. Was bedeutet die Ausgabe? Wo sehen Sie die Zugriffsrechte der Dateien? Wem gehören die Dateien und wer darf wie zugreifen? Eine Erläuterung zu den Zugriffsrechten finden Sie unter https://wiki.ubuntuusers.de/Rechte/.
b) Nutzen Sie den Befehl `chown`, um den Besitzer von Dateien zu ändern. Die Dateien alice.txt und alicebob.txt sollen alice und der Gruppe alice gehören. Bob.txt und world.txt sollen bob und der Gruppe bob gehören. Hierfür benötigen Sie wieder root-Rechte. Die Syntax des Befehls `chown` können Sie durch die Angabe von `chown --help`, durch Aufruf der manpages (`man chown`) oder durch Suchen im Internet erlernen.
c) Wechseln Sie mit dem Befehl `sudo su alice` in die Rolle von Alice. Bestätigen Sie mit dem Befehl `whoami`, dass Sie nun gerade Alice sind. Versuchen Sie mit `cat <Dateiname>` den Inhalt einer Datei auszugeben, die Bob gehört. Können Sie den Inhalt der Datei lesen? Wieso oder wieso nicht?
d) Beenden Sie mit dem Befehl `exit` die aktuelle Konsole. Sie kehren zur ursprünglichen Konsole mit dem ursprünglichen Benutzer zurück. Setzen Sie die Dateirechte so, dass nur der Besitzer der Datei lesen und schreibend darauf Zugriff hat. Geben Sie die Ausgabe von ls -l an. Prüfen Sie aus der Rolle von Alice, Bob und Eve, ob Zugriffe korrekt verweigert werden.
e) Die Datei alicebob.txt soll sowohl von Alice und Bob, aber nicht von Eve bearbeitet und gelesen werden können. Wie können Sie das erreichen? Tipp: Machen Sie sich mit den Befehlen `groupadd` und `chgrp` vertraut. Mit dem Befehl `useradd` können Sie einen Benutzer einer Gruppe hinzufügen. Geben Sie die Ausgabe von `ls -l` an. „Schlüpfen“ Sie in die Rolle von Alice, Bob und Eve, um den Zugriff auf die Datei alicebob.txt zu prüfen.
f) Die Datei world.txt soll von allen gelesen und bearbeitet werden können. Wie können Sie die Dateirechte entsprechend anpassen? Wie sieht danach die Ausgabe von `ls -l` aus?

Aufgabe 3

In der Vorlesung haben Sie Kerberos kennengelernt. Mit Kerberos können Sie innerhalb eines Netzwerkes Single-Sign-On (SSO) umsetzen. Das bedeutet, dass Sie sich nur einmalig anmelden und danach weitere Dienste ohne erneute Authentifizierung nutzen können. Kerberos arbeitet jedoch nur in lokalen Netzwerken.

Ein ähnliches Verfahren kann zur Anmeldung in sogenannten Identitäts-Föderationen umgesetzt werden. Eine verbreitete Lösung basiert auf Security Assertion Markup Language (SAML). Dies ist ein offener XML-Standard, um Authentifizierungs- und Autorisierungsinformationen zu übertragen. Die HFU nutzt SAML, um die Anmeldung an Felix und anderen Diensten zu ermöglichen.

In SAML existieren zwei Entitäten: Identity Provider (IdP) und Service Provider (SP). Ein IdP umfasst Benutzerdaten und ermöglicht einen Login. Ein SP ist ein Dienst, der die Authentifizierung an den IdP auslagert. Felix ist ein SP, der den IdP der HFU nutzt. Unter der Seite www.switch.ch/aai/demo/ finden Sie nähere Informationen zur Arbeitsweise von SAML (hier wird Shibboleth gezeigt, eine häufig eingesetzte Implementierung von SAML).

a) Gehen Sie auf die Seite von bwSync&Share unter bwsyncandshare.kit.edu/ und versuchen Sie sich einzuloggen. Der Dienst bwSync&Share (SP) ist auf einem Server der Universität Karlsruhe (KIT) gehostet. Wieso können Sie sich dennoch einloggen?

b) Welche Hosts werden beim Aufrufen der bwSync&Share Seite nacheinander aufgerufen, bis Sie Zugang zum Dienst bekommen? Benutzen Sie ein Inkognito-Fenster, damit keine bereits existierenden Sitzungen aktiv sind. Welche Daten werden übertragen?

c) Wenn Sie innerhalb Ihrer aktiven Inkognito-Sitzung auf Felix navigieren, müssen Sie sich nicht erneut einloggen. Wieso ist das so?

d) Können Sie einen Vergleich zu Kerberos ziehen? Was entspricht am ehesten den Tickets, mit denen Kerberos arbeitet?

Verwenden Sie die Entwickler-Konsole Ihres Browsers, um an die Details der übertragenen Daten zu gelangen. Sowohl unter Firefox, als auch unter Chrome starten die Entwicklerkonsole mit F12. Anleitungen für MacOS und Safari finden sich unter https://intercom.help/scoutpad/de/articles/2419374-so-offnest-du-die-entwickler-konsole. Aktivieren. Sie die Option „Preserve logs“:

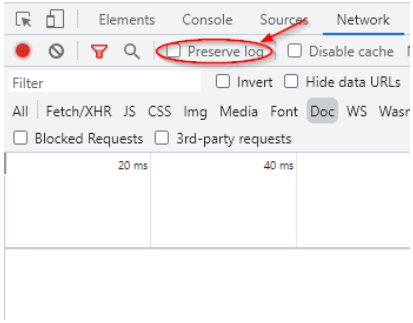


Abbildung 1: Funktion "Preserve log" unter Chrome

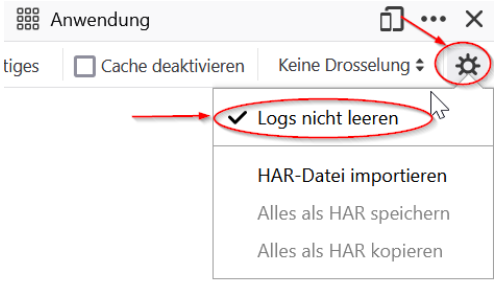
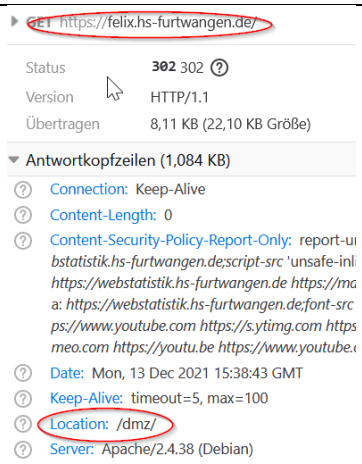


Abbildung 2: Funktion "Logs nicht leeren" unter Firefox

Hilfestellung zur Abarbeitung: In diesem Beispiel wird der Ablauf für die Anmeldung an Felix beantwortet. Hierin erfahren Sie, wie Sie die Antworten von IdP und SP interpretieren können.

1.	Seite https://felix.hs-furtwangen.de/ wird aufgerufen. Eine Weiterleitung auf https://felix.hs-furtwangen.de/dmz/ findet statt	
2a	Anmelde-Seite wird unter https://felix.hs-furtwangen.de/dmz/ angezeigt. Ein Klick auf „Anmelden“ führt zu einer wiederholten Weiterleitung, die letztendlich zum IdP der HFU führt. Die Weiterleitung enthält als Parameter einen komprimierten und URL-codierten Base64 SAML-Request für den IdP.	klick führt zur Weiterleitung zum IdP:

	Die URL-Codierung stellt sicher, dass nur ASCII-Zeichen vorkommen, die über einen HTTP GET aufruf übertragen werden können.	GET https://felix.hs-furtwangen.de/shib/ Status 302 Found HTTP Redirect Version HTTP/1.1 Übertragen 2,50 KB (3,39 KB Größe) Referrer Policy strict-origin-when-cross-origin Antwortkopfzeilen (1,364 KB) Unformatiert Cache-Control: private,no-store,no-cache,max-age=0 Connection: Keep-Alive Content-Length: 1365 Content-Type: text/html; charset=iso-8859-1 Date: Mon, 13 Dec 2021 16:06:14 GMT Expires: Wed, 01 Jan 1997 12:00:00 GMT Keep-Alive: timeout=5, max=95 Location: https://idp2.hs-furtwangen.de/idp/profile/SAML2/Redirect/SSO?SAMLRequest=hZJdT8IwFIb%2FytL70bXIiA0jmXAhCQph6IU3ptvOWJPSzp5O8N87PlSMCd62p8973icdodzqRqStr80K3lpAH%2By32qA4XiSkdUZYiQqFkVtA4QuRpQ9zwXuRaJz1trCaBCkiOK%2BsmViD7RZcBu5dFfC0miek9r5BQWkFWu17NYZV6%2FxOmg2YXgk0q1WeWw2%2B7iFaeqBzulxkaxJMu3WUkQfwD0aVDf9L6U5pt0%2BlNJwRKyiVg8LTLFuQYDZNyGver277LJYyiof5bRTxwVCygeyzPOYlH0bdGGILM4NeGp8QHnEWMh6y%2FprFIooFu3khwfJc%2B06ZUpnNdUf5aQjF%2FXq9DE%2B1nsHhsVI3QMajg2lxDHYX7q9j5ZdwMv5HL37rpVZLT7EZ0YvEU3wjHruI2XRptSo%2BglRru...30f2b545c920742127c60385a986114d062254bbbf7bbaa0131f470a9823&SigAlg=http%3A%2F%2Fwww.w3.org%2F2001%2F04%2Fxmldsig-more%23rsa-sha256&Signature=tcT%2B8kIvEswjxtzuNwe4bDhV3eCA7xFjJxc%2F4ybjyN3V7RwxLHaVpX7aUeHKeWBsB5Akbma8sZTkfMMLov1AjpixaFOVWFLrv0ixlUltaToWk7376LJBc%2B40HZONOleaCkxwafsF0thJowa8Kv8GTZGOO8B1IrFK%2F5
2b	Inhalt des SAML Requests dekodieren und dekomprimieren, um an Inhalt heranzukommen. Der SAML-Request teilt dem IdP mit, wohin eine Antwort gesendet werden soll (AssertionConsumerServiceURL), für welchen IdP die Nachricht erstellt wurde (Destination) und gibt eine eindeutige Kennung der Transaktion an. Sie müssen den Inhalt des SAML-Requests nicht vollständig verstehen. Es genügt die eindeutigen Kennungen erkennen zu können.	Unter https://www.samltool.com/url.php zuerst den SAMLRequest URL Dekodieren: URL Decode Data to be URL Decoded hZJdT8IwFIb%2FytL70bXIiA0jmXAhCQph6IU3ptvOWJPSzp5O8N87PlSMCd62p8973icdodzqRqStr80K3lpAH%2By32qA4XiSkdUZYiQqFkVtA4QuRpQ9zwXuRaJz1trCaBCkiOK%2BsmViD7RZcBu5dFfC0miek9r5BQWkFWu17NYZV6%2FxOmg2YXgk0q1WeWw2%2B7iFaeqBzulxkaxJMu3WUkQfwD0aVDf9L6U5pt0%2BlNJwRKyiVg8LTLFuQYDZNyGver277LJYyiof5bRTxwVCygeyzPOYlH0bdGG URL Decoded Data hZJdT8IwFIb/ytL70bXIiA0jmXAhCQph6IU3ptvOWJPSzp5O8N87PlSMCd62p8973icdodzqRqStr80K3lpAH+y32qA4XiSkdUZYiQqFkVtA4QuRpQ9zwXuRaJz1trCaBCkiOK+smViD7RZcBu5dFfC0miek9r5BQWkFWu17NYZV6/xOmg2YXgk0q1WeWw2+7iFaeqBzulxkaxJMu3WUkQfwD0aVDf9L6U5pt0+lNJwRKyiVg8LTLFuQYDZNyGver277LJYyiof5bRTxwVCygeyzPOYlH0bdGGILM4NeGp8QH Der SAML-Request ist ein komprimierter, als auch Base64- und URL-codiert. Unter https://www.samltool.com/decode.php lässt sich der SAML Request lesbar machen: Deflated and Encoded XML hZJdT8IwFIb/ytL70bXIiA0jmXAhCQph6IU3ptvOWJPSzp5O8N87PlSMCd62p8973icdodzqRqStr80K3lpAH+y32qA4XiSkdUZYiQqFkVtA4QuRpQ9zwXuRaJz1trCaBCkiOK+smViD7RZcBu5dFfC0miek9r5BQWkFWu17NYZV6/xOmg2YXgk0q1WeWw2+7iFaeqBzulxkaxJMu3WUkQfwD0aVDf9L6U5pt0+lNJwRKyiVg8LTLFuQYDZNyGver277LJYyiof5bRTxwVCygeyzPOYlH0bdGGILM4NeGp8QHnEWMh6y/prFIooFu3khwfJc+06ZUpnNdUf5aQjF/Xq9DE+1nsHhsVI3QMajg2lxDHYX7q9j5ZdwMv5HL37rpVZLT7EZ0YvEU3wjHruI2XRptSo+glRru5s4kB4Swggdn578/ifjTw== Ergebnis: XML <samlp:AuthnRequest xmlns:samlp="urn:oasis:names:tc:SAML:2.0:protocol" AssertionConsumerServiceURL="https://felix.hs-furtwangen.de/Shibboleth.sso/SAML2/POST" Destination="https://idp2.hs-furtwangen.de/idp/profile/SAML2/Redirect/SSO" ID="_b3f9316aa067b900257a15a31b62d270" IssueInstant="2021-12-13T16:06:14Z" ProtocolBinding="urn:oasis:names:tc:SAML:2.0:bindings:HTTP-POST" Version="2.0"> <saml:Issuer xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion">https://felix.hs-furtwangen.de/shibboleth/olat/sp</saml:Issuer><samlp:NameIDPolicy AllowCreate="1"/> </samlp:AuthnRequest>
3a	Der IdP zeigt die Login-Seite an. Anmeldeinformationen werden per HTTP POST an den IdP übertragen. Daraufhin antwortet der IdP und teilt ein Cookie mit einer Sitzungskennung.	Benutzername und Passwort wird per HTTP POST an IDP übertragen: POST https://idp2.hs-furtwangen.de/idp/profile/SAML2/Redirect/SSO?execution=e1s2 IdP erstellt eine Sitzung und vergibt ID per Cookie: Antwort-Cookies shib_idp_session: httpOnly: true path: "/idp" secure: true value: "d037a2[redacted]
3b	Die Antwort des IDPs ist eine Webseite mit einer sogenannten „Hidden Form“: Ein Formularfeld, dass bereits	Antwort des IdPs nach Übertagung von Benutzername und Passwort:

	ausgefüllt ist und mit JavaScript an den Assertion Consumer Service des SPs (aus Schritt 2b) gesendet wird	Kopfzeilen Cookies Anfrage Antwort Zeit Sicherheit HTML 1 <!DOCTYPE html> 2 <html> 3 <head> 4 <meta charset="utf-8" /> 5 </head> 6 <body onload="document.forms[0].submit()"> 7 <noscript> 8 9 Note: Since your browser does not support JavaScript, 10 you must press the Continue button once to proceed. 11 12 </noscript> 13 14 <form action="https://felix.hs-furtwangen.de/Shibboleth.sso& 15 16 <input type="hidden" name="RelayState" value="ss:mem:a2a230f2b5 17 18 <input type="hidden" name="SAMLResponse" value="PD94bWwgdmVyc2lvbj0iMS4wl 19 20 <noscript> 21 22 <input type="submit" value="Continue"/> 23 24 </noscript> 25 </form> 26 </body> 27 </html> Nach dem Laden der Seite soll das Formularfeld vom Browser übertragen werden Ziel des Formulafeldes SAMLResponse (Antwort vom IdP zum SP)
3c	Inhalt der SAML-Antwort vom IdP an SP	Base64 dekodieren unter https://www.samltool.com/base64.php. Antwort ist mit dem öffentlichen Schlüssel des SPs verschlüsselt und nicht lesbar. Antwort beinhaltet Informationen, ob der Benutzer einen gültigen Account hat und weitere Attribute, wie Name und Gruppenzugehörigkeit. XML to be Base64 Decode PD94bWwgdmVyc2lvbj0iMS4wIiBlbmNvZGluZz0iVVR GLTgiPz48c2FtbDJwOlJlc3BvbnNlIHhtbG5zOnNhbWwy cD0idXJuOm9hc2lzOm5hbWVzOnRjOlNBTUw6Mi4wO nByb3RvY29sIiBEZXN0aW5hdGlvbj0iaHR0cHM6Ly9m ZWxpeC5ocy1mdXJ0d2FuZ2VuLmRlL1NoaWJib2xldGg uc3NvL1NBTUwyL1BPU1QiIElEPSJfNWM0OTNlYzljNjcw MTJhNGUwNDAwMGZlNTZiYTQ0NjUiIEluUmVzcG9uc2 VUbzOiX2IzZjkzMTZhYTA2N2I5MDAyNTdhMTVhMzFiNj JkMjcwIiBJc3N1ZUluc3RhbnQ9IjIwMjEtMTItMTNUMTY6 Base64 Decoded XML o48PnS4L4BORot5NLAw+f0uVp50hyvntdNtUGNIHH+S OvG8DXYGUCStekOHSqNDmELwLjHqp7NDe 8Oz9pn0ooIuQ/mlfw0esSpWEOeUHv6kCUpN0SX /KnwYh6Qdoyb/+lXXlsun903w=</ds:X509Certificate> </ds:X509Data></ds:KeyInfo></ds:Signature> <saml2p:Status><saml2p:StatusCode Value="urn:oasis:names:tc:SAML:2.0:status:Success"/> </saml2p:Status><saml2:EncryptedAssertion xmlns:saml2="urn:oasis:names:tc:SAML:2.0:assertion"> <xenc:EncryptedData xmlns:xenc="http://www.w3.org	
4	SAML-Antwort wird an den SAML-Endpunkt des SP (Felix) weitergereicht. Dort wird die Antwort geprüft und eine lokale Session erstellt. Die Session wird als Cookie übertragen (_shibsession). Es erfolgt eine Weiterleitung an https://felix.hs-furtwangen.de/shib/.	POST https://felix.hs-furtwangen.de/Shibboleth.sso/SAML2/POST Antwort-Cookies _shibsession_64656661756c7468747470733a2f2f6665 httpOnly: true path: "/" secure: true value: "_ae5cb7c4ca2409aa4e4cb3a8f69dbcfb" PS: Bitte machen Sie den Inhalt Ihres _shibsession Cookies unkenntlich.
5	https://felix.hs-furtwangen.de/shib leitet an den Inhalt von Felix weiter.	Benutzer ist angemeldet. Bei einem erneuten Aufruf auf Felix, wird die aktive Sitzung an Hand des Cookies _ shibsession erkannt.

Aufgabe 4 (Aufgabenspezial zur aktuellen, schweren Sicherheitslücke in Log4j)

Letzte Woche wurde in der Java-Bibliothek Log4j eine schwerwiegende Sicherheitslücke bekannt. Diese Bibliothek dient dazu, Logdateien zu erstellen und wird in unzähligen Java-Projekten eingesetzt. Beispielcode und einen Exploit finden Sie im Felix-Kurs (siehe Aufgabe 4d-f).

a) Informieren Sie sich im Internet über die Sicherheitslücke. Beschreiben Sie, wie sich die Lücke ausnutzen lässt und worin die zentrale(n) Schwäche(n) liegt / liegen.

b) Welche CVE-Nummer wurde der Sicherheitslücke zugewiesen? Eine CVE-Nummer ist eine eindeutige Kennung zu einer Schwachstelle.
c) Die MITRE Corporation sammelt Informationen zu Schwachstellen, die zu Sicherheitslücken führen können. Den Schwachstellen werden sogenannte CWE (Common Weakness Enumeration) Nummern zugewiesen. Welche Schwachstelle(n) führte Ihrer Meinung nach zu dieser Sicherheitslücke? Eine „Top-25"-Liste finden Sie unter https://cwe.mitre.org/top25/archive/2021/2021_cwe_top25.html
d) Im Felix-Kurs finden Sie einen Beispielcode, der die Sicherheitslücke beinhaltet, als auch einen Exploit (Code, der die Sicherheitslücke ausnutzt). Importieren Sie die ZIP-Archive in Eclipse (File -> Import -> General -> Existing Projects into Workspace). Somit werden Abhängigkeiten mit kopiert. Starten Sie die Datei „VulnerableServer.java" aus dem Projekt VulnerableLog4jServer. Rufen Sie http://127.0.0.1:8080/irgendetwas auf. Was macht der Server-Code? Welche Code-Zeile führt zur Schwachstelle?
e) Starten Sie nun den Code, der Schadcode an den Ausnutzbaren Server aus Teil d) sendet. Diesen finden Sie in der Datei „Exploit.java" im Projekt Log4jExploit. Dieser Code startet einen LDAP-Server[1]. Dieser Server antwortet auf Anfragen mit einem serialisierten Objekt. Versuchen Sie die Schwachstelle auszunutzen. Der Code stammt von https://github.com/HyCraftHD/Log4J-RCE-Proof-Of-Concept.
f) Wie könnten Sie die Schwachstelle verhindern (ohne die Schwachstelle in Log4j zu patchen)?

Diese Anleitung und der bereitgestellte Code dienen der Lehre, mit dem Zweck das Entstehen von Sicherheitslücken zu verstehen, Sicherheitslücken zu erkennen und diese zu beheben. Verwenden Sie diesen Code ausschließlich zu diesem Zweck. Lassen Sie den manipulierten LDAP-Server nicht auf Anfragen aus dem Internet reagieren.

[1] LDAP steht für Lightweigt Directory Access Protocol und ist eine sogenannter Verzeichnisdienst. Ein solcher Dienst wird genutzt, um Informationen jeglicher Art abzufragen und zu verändern. Hauptsächlich wird LDAP zur Authentifizierung, Autorisierung und Benutzerverwaltung genutzt.